Studento data inventory and security summary

For district technology directors and data protection officers. Verified against the code on 2026-11-01 (`server/functions/api/[[path]].ts`, `src/lib/account.ts`, `src/lib/store.ts`).

What runs where

Part	Where	Student data?
The app (clock, alerts, widgets, themes, planner, notes, grades)	On the device	Yes, on the device only. Never leaves it unless the student signs in.
Studento server	Cloudflare Pages Functions + D1 database, United States	Only for signed-in students: username, password hash, saved schedule and settings.
Shared schools and bell schedules	Studento server	No student data. Public list of schools and bell times.
Schedule reader (optional, signed in only)	Server, then Groq / Google for one request	The photo or typed text of the schedule, discarded after the answer.
App updates	Expo EAS Update	No student data.

Data elements

- **On the device:** class names, rooms, bell schedule choice, custom days, display settings, homework list, countdowns, notes, grade percentages. Entered by the student. Stays on the device. Removed when the app is deleted.
- **On the server (only with an account):** username (student-chosen), password hash (PBKDF2- SHA256, 100,000 iterations, 16-byte salt), hashed session token, the same schedule and settings as above, timestamps.
- **Never collected:** legal name, email, phone, address, date of birth, student ID, school ID number, grade level, location, photos of people, contacts, calendar, device identifier, advertising identifier, analytics or crash telemetry.

Network connections the app makes

Host	When	What
studento-app.pages.dev	Searching schools, signing in, syncing, reporting, reading a schedule photo	HTTPS/TLS only
u.expo.dev	On launch	Checks for a JavaScript update; no user data
None other		No ads, no analytics, no social SDKs

Controls

- Accounts are optional; the app is complete without one. Districts can tell students to skip the account step.
- In-app account deletion removes the user, token and saved data in one request.
- Rate limits on sign-up, sign-in, the reader and reports.
- One administrator account (the developer). Admin actions: remove a shared school or schedule, turn sign-ups / sharing / the reader off (kill switches).
- Reports on shared content go to the administrator only; there is no messaging between users.
- Push notifications are not used. Bell alerts are local notifications scheduled on the device; the push entitlement is removed at build time.
- Source code is public: https://github.com/theprojectmaker/studento-ios

Retention

- Device data: until the student deletes it or the app.
- Account data: until the student deletes the account, or the District asks for deletion (completed within 30 days).
- Schedule photos / text sent to the reader: not stored; processed and discarded.
- Server logs: Cloudflare request logs, no bodies, retained by Cloudflare for its standard period (under 30 days).

Compliance notes

- COPPA: no personal information is collected from children under 13 beyond a self-chosen username; no account is required.

- FERPA: Studento holds no education records from the school. Everything is student-entered.
- Ed Law §2-d / 8 NYCRR Part 121: see `PARENTS-BILL-OF-RIGHTS-SUPPLEMENT.md`.